HUSKEY POCKET

Whitepaper de Seguridad y Arquitectura

Gestor de contraseñas de hardware sobre ESP32-S3

Revisión 4 — arquitectura, pruebas y límites actuales

Documento técnico de diseño, límites y modelo de amenazas

Contenido

Contenido 2
Nota sobre esta revisión 3
1. Introducción 3
2. Modelo de amenazas 4
3. Arquitectura general 5
4. Arquitectura del almacenamiento 5
5. Modelo criptográfico 6
6. Gestión de claves 6
7. Flujo de autenticación 7
8. Protección contra fuerza bruta 7
9. Protección post-restablecimiento (FRP) 8
10. PIN señuelo 8
11. Modo perdido (mano muerta) 8
12. Bloqueo por arrebato (Snatch Lock) 9
13. Exportación e importación 9
14. Actualizaciones del firmware 10
15. Protección física 10
16. Bluetooth 10
17. Modo de almacenamiento USB 11
18. TOTP y política de diagnóstico 12
21. Limitaciones 13
22. Cambios de la revisión 4 13
23. Cambios de la revisión 3 14
24. Cambios de la revisión 2 14
25. Preguntas frecuentes 15
26. Glosario 15

Nota sobre esta revisión

Esta revisión describe la arquitectura actual del firmware y las pruebas funcionales realizadas. Dos revisiones de memoria asistidas por IA examinaron fugas y problemas de gestión de memoria; las 16 pruebas reportadas pasaron en el código evaluado en ese momento. No se ha realizado una auditoría de seguridad. Estas revisiones no certifican la ausencia de vulnerabilidades.

> *Secure Boot V2 está habilitado en la unidad del autor. La configuración de cifrado de flash y las opciones de recuperación dependen del aprovisionamiento de cada unidad. Este documento no constituye una auditoría de seguridad ni una certificación del firmware.*

1. Introducción

¿Qué es Huskey Pocket?

Huskey Pocket es un gestor de contraseñas de hardware: un dispositivo físico e independiente, sin conexión a internet ni a la nube, que almacena credenciales cifradas y las entrega a una computadora emulando un teclado Bluetooth o USB. El usuario nunca escribe ni copia sus contraseñas; el dispositivo las teclea por él tras verificar un PIN en su propia pantalla táctil.

¿Qué problema resuelve?

Los gestores de contraseñas de software (extensiones de navegador o apps en la nube) dependen de la seguridad del sistema operativo y del navegador donde corren. Si esa computadora está comprometida, el gestor entero puede quedar expuesto. Huskey Pocket separa el almacenamiento de credenciales de la computadora que las usa. La bóveda cifrada se almacena localmente. Las funciones USB/Bluetooth envían los campos que el usuario ordena escribir.

Filosofía de diseño

- Sin nube, sin cuenta y sin sincronización automática. El dueño del dispositivo es el único punto de confianza.
- Cada intento de PIN paga el costo completo de la derivación de clave por PBKDF2. No existe un atajo barato para verificar candidatos.
- Fallar de forma segura. Ante duda, como un RTC desincronizado, el sistema prefiere no actuar antes que borrar datos por error.
- El firmware no incluye funciones Wi-Fi ni sincronización en la nube. Utiliza USB y Bluetooth como canales de teclado y ofrece acceso USB a la microSD en un modo exclusivo.
- El material sensible no sale del dispositivo por ningún canal de diagnóstico. Ningún secreto, clave ni código se registra por el puerto serie.

2. Modelo de amenazas

Esta es la sección más importante del documento: define qué promete Huskey Pocket y, con la misma claridad, qué no promete.

Protege contra

- Robo del dispositivo. El vault permanece cifrado sin el PIN, sin ninguna clave de recuperación de fábrica que lo evite.
- Ataques de fuerza bruta al PIN. Cada intento paga el costo completo de PBKDF2 (50 000 iteraciones) y el sistema inicia el restablecimiento de fábrica tras 5 intentos consecutivos fallidos, con el contador se guarda antes de verificar el PIN.
- Pérdida prolongada del dispositivo. El Modo perdido borra el contenido tras N días sin desbloqueo real, si el usuario lo activó.
- Robo seguido de reconfiguración. Factory Reset Protection (FRP) exige el PIN original tras cualquier borrado de fábrica, con contador de intentos persistente que no se reinicia por corte de energía.
- PIN señuelo. El PIN señuelo puede abrir una bóveda separada vacía. El código calcula las claves candidata real y señuelo antes de verificar; no se ha auditado la resistencia a ataques de temporización.
- Arrebato físico con el dispositivo desbloqueado. El firmware consulta el sensor inercial y bloquea el dispositivo si las lecturas superan los umbrales configurados; la respuesta se evalúa por software y no tiene un tiempo fijo garantizado.
- Acceso no autorizado al almacenamiento. Cada campo sensible se cifra con AES-256-CBC y un IV propio; el salt se utiliza para derivar la clave, y el descifrado valida el relleno completo antes de aceptar los datos.

No protege contra

- Un usuario que revela voluntariamente su PIN bajo engaño (no coacción; para coacción existe el PIN señuelo).
- Malware ya instalado en la computadora donde se usa el teclado. Huskey Pocket teclea las credenciales igual que lo haría el usuario y no puede saber si el sistema receptor está comprometido.
- Ataques de laboratorio sofisticados sobre el chip (side-channel avanzado, decapsulado). Secure Boot está habilitado en la unidad del autor. El estado de Flash Encryption y los eFuses restantes no se ha verificado.
- Ingeniería social dirigida al usuario, fuera del propio dispositivo.

3. Arquitectura general

Huskey Pocket corre sobre un Waveshare ESP32-S3-Touch-LCD-2.8. Los componentes principales:

Componente	Detalle
MCU	ESP32-S3, con aceleración criptográfica por hardware vía mbedTLS.
Almacenamiento	Flash interna con NVS para configuración y valores de control, y una partición LittleFS para los registros cifrados del vault.
RTC	PCF85063ATL dedicado; necesita una batería externa de respaldo para conservar la hora apagado. Se usa para TOTP y Modo perdido.
IMU	QMI8658C (acelerómetro + giroscopio) en el bus I2C compartido con el RTC. Usado por el Bloqueo por arrebato.
MicroSD	Exclusivamente para exportación/importación cifrada y modo de almacenamiento masivo activable manualmente.
Pantalla	ST7789 240×320 con controlador táctil CST328 en bus I2C independiente.
Bluetooth	NimBLE, perfil HID de teclado únicamente. Emparejamiento con confirmación numérica y transmisión solo sobre enlace cifrado y autenticado.
USB	Teclado HID nativo o almacenamiento masivo, exclusivo, con salida automática al desconectar el cable.

4. Arquitectura del almacenamiento

NVS

- Namespace del vault: valor de control del PIN real (derivado, no el PIN) y del PIN señuelo.
- Namespace de seguridad: contador de intentos fallidos, escrito de forma persistente antes de cada verificación.
- Namespace de FRP: valor de control del PIN de FRP, bandera de bloqueo permanente y contador de intentos de FRP. Nunca se borra en un restablecimiento de fábrica.
- Namespaces del vault señuelo: existen para su configuración, pero las operaciones de guardado sobre el señuelo están completamente simuladas y no escriben datos reales. Se limpian en el factory reset.
- Namespace de preferencias: tema, idioma, autobloqueo, layout, días de Modo perdido, timestamp del último desbloqueo real, nivel de Bloqueo por arrebato y preferencia de solo-lectura del modo USB. No contiene secretos.

LittleFS

Contiene los registros del vault en formato binario de tamaño fijo por entrada, donde cada campo sensible (nombre, usuario, contraseña, secreto, notas) se cifra individualmente con su propio IV y relleno PKCS7. También contiene tres archivos de salt persistentes (PIN real, PIN señuelo y FRP), cada uno generado una única vez.

¿Qué está cifrado y qué no?

Cifrado con AES-256-CBC	En claro (metadatos de bajo riesgo)
Contraseñas, secretos, notas, secretos TOTP y nombres de cada entrada.	IDs de categoría, preferencias de interfaz, contador de intentos, configuración de Modo perdido y del Bloqueo por arrebato, y sus timestamps.

Los metadatos en claro se consideraron de bajo riesgo porque no permiten reconstruir credenciales ni distinguir el vault real del señuelo desde fuera del dispositivo.

5. Modelo criptográfico

Parámetro	Valor
Cifrado simétrico	AES-256-CBC (mbedTLS)
Relleno (padding)	PKCS7, con validación completa de los bytes de relleno al descifrar
Derivación de clave	PBKDF2-HMAC-SHA256
Iteraciones (PIN del dispositivo)	50 000
Iteraciones (exportación cifrada)	100 000, con contraseña de exportación independiente del PIN. El importador rechaza archivos que declaren menos iteraciones.
Salt	16 bytes aleatorios, generado una sola vez y persistido en LittleFS.
IV	16 bytes aleatorios en cada operación de cifrado, almacenados junto al ciphertext y nunca reutilizados.

Se eligió CBC en lugar de un modo autenticado (GCM) por simplicidad de implementación en el microcontrolador. La autenticidad se resuelve aparte mediante un esquema de valor de control y, en las exportaciones, un identificador fijo de verificación cifrado como primer bloque. Es una limitación reconocida (sección 19).

PBKDF2 se aplica sin atajos: no existe un hash barato intermedio para validar un PIN candidato antes de derivar la clave completa. Cada intento paga el costo completo de las 50 000 iteraciones.

> *Corrección de la revisión 2: el descifrado ahora valida que la longitud del ciphertext sea múltiplo del bloque y que todos los bytes de relleno PKCS7 sean coherentes, antes de aceptar los datos. Esto cierra un posible acceso a memoria fuera de rango ante registros corruptos y reduce la exposición a un oráculo de relleno parcial.*

6. Gestión de claves

La clave de 256 bits derivada del PIN existe únicamente en RAM y nunca se escribe a Flash, NVS ni SD en texto plano.

- Nace al verificar el PIN correctamente contra el valor de control almacenado.
- Vive en RAM mientras el vault está desbloqueado.

- Se destruye mediante limpieza explícita de memoria al bloquear, al vencer el timeout de autobloqueo y como parte de un restablecimiento de fábrica.
- Un restablecimiento de fábrica (por fuerza bruta o Modo perdido) también pone la clave en cero antes de reiniciar.

Deep Sleep

Antes de entrar en Deep Sleep no se hace una limpieza explícita de la clave en software: no hace falta, porque el Deep Sleep del ESP32-S3 apaga la RAM principal. Solo sobreviven las memorias RTC lenta y rápida, y la clave vive en RAM común. Al despertar, el chip arranca desde cero y muestra la pantalla de PIN. La clave se destruye por el propio apagado de hardware.

Además, justo antes del Deep Sleep se apagan explícitamente el panel, el controlador táctil y la tarjeta SD, que no se apagan solos. Esto no cambia la seguridad de la clave pero reduce de forma significativa el consumo durante el sueño.

7. Flujo de autenticación

Al introducir el PIN, el dispositivo deriva SIEMPRE dos claves candidatas —una contra el salt del señuelo y otra contra el salt del PIN real— antes de tomar cualquier decisión. Después verifica cada una contra su valor de control. Como ambas rutas ejecutan el mismo número de derivaciones PBKDF2, el tiempo de respuesta es constante y no filtra cuál PIN se probó ni cuál vault se abrió.

> *Corrección de la revisión 2: en la versión anterior el señuelo se derivaba primero y, si no coincidía, se derivaba el real, de modo que un PIN señuelo válido costaba la mitad de tiempo que uno real. Esa diferencia permitía distinguir por cronometraje si se había abierto el vault señuelo, justo lo que el modo señuelo debe ocultar. Ahora el costo es idéntico en ambos casos.*

¿Qué ocurre si el PIN es incorrecto?

El contador persistente de fallos se incrementa y se guarda ANTES de evaluar el intento, y solo se reinicia tras un desbloqueo correcto confirmado. Del primer al tercer fallo se informa cuántos intentos quedan; en el cuarto se muestra una advertencia de último intento; Tras cinco intentos consecutivos fallidos, el firmware inicia un restablecimiento de fábrica y se reinicia.

> *Corrección de la revisión 2: antes el contador se escribía después del intento, de modo que un corte de energía entre la verificación y la escritura podía «regalar» reintentos. Reservar el intento por adelantado cierra ese bypass.*

¿Qué ocurre en el quinto fallo?

Restablecimiento de fábrica inmediato: se borra el vault, las categorías, las preferencias de interfaz, el contador de intentos y los residuos del vault señuelo, pero no el registro de Factory Reset Protection, que sobrevive de forma intencional.

8. Protección contra fuerza bruta

Cinco intentos consecutivos fallidos es un umbral bajo a propósito. Un atacante con el dispositivo físico y sin el PIN tiene una ventana mínima para adivinar antes de perder el contenido; para un usuario legítimo, cinco intentos bastan en uso normal.

Un bloqueo temporal por sí solo no detiene a un atacante con tiempo ilimitado y el dispositivo en mano. Borrar el contenido convierte el ataque de fuerza bruta en un ataque sin objetivo: no queda nada que descifrar. Tras el borrado, el dispositivo no es reconfigurable de inmediato porque FRP exige el PIN original.

> *La eficacia de esta protección depende de la configuración del hardware y de la protección de la memoria flash. No se debe tratar el comportamiento de un aprovisionamiento como una garantía para todas las unidades.*

9. Protección post-restablecimiento (FRP)

Factory Reset Protection evita que un restablecimiento de fábrica —propio o forzado por un atacante— convierta el dispositivo robado en uno limpio listo para reconfigurar.

- Al configurar el PIN por primera vez, este se guarda también, con su propio salt y derivación, en un namespace separado que nunca se borra en un restablecimiento de fábrica.
- Tras cualquier restablecimiento, al encender el dispositivo detecta que existe un registro de FRP pero no hay PIN activo, y exige ese PIN original antes de permitir configurar uno nuevo.
- Tres intentos fallidos contra el PIN de FRP bloquean el dispositivo de forma permanente. El contador de esos intentos es persistente: sobrevive a un corte de energía y a un reinicio.
- La única forma de recuperar el dispositivo en estado de bloqueo permanente es reflashear el firmware completo, borrando toda la Flash y con ella cualquier posibilidad de recuperar el contenido anterior.

> *Corrección de la revisión 2: antes el contador de intentos de FRP vivía solo en memoria volátil, de modo que cortar la alimentación tras cada intento permitía reintentos ilimitados contra el PIN de FRP. Ahora se persiste y se incrementa antes de verificar.*

10. PIN señuelo

Resuelve la coacción física. Si alguien obliga al usuario a desbloquear bajo amenaza, el PIN señuelo abre un vault distinto, visualmente idéntico pero vacío, sin que la interfaz revele que existe un vault real detrás de otro PIN.

El PIN señuelo se deriva y verifica igual que el real, contra su propio salt independiente y en tiempo constante respecto al real. Al autenticar con él, el dispositivo entra en modo señuelo: todas las operaciones de guardado, edición y borrado reportan éxito a la interfaz pero no escriben nada a almacenamiento persistente. El vault señuelo siempre se ve funcional y nunca acumula datos reales.

El modo señuelo incluye un temporizador de auto-reinicio configurable (5 minutos por defecto) que, tras un desbloqueo real posterior, limpia cualquier resto simulado de la sesión señuelo.

11. Modo perdido (mano muerta)

Evita que un dispositivo perdido u olvidado quede disponible indefinidamente para que quien lo encuentre lo intente forzar sin límite de tiempo.

Solo cuenta como actividad un desbloqueo real y exitoso con el PIN verdadero, nunca con el señuelo; se registra un timestamp cada vez que ocurre. Una función de verificación se ejecuta una vez en cada arranque, antes de la pantalla de PIN, usando el RTC dedicado como única fuente de tiempo. Si pasaron tantos o más días que el límite configurado desde el último desbloqueo real, se ejecuta un restablecimiento de fábrica.

Si el RTC pierde la hora o marca una fecha anterior al último desbloqueo registrado, el Modo perdido no se activa. Un salto hacia adelante del RTC puede adelantar el borrado.

12. Bloqueo por arrebato (Snatch Lock)

Cubre el otro escenario de coacción física: que alguien arrebate el dispositivo de la mano mientras está desbloqueado. El PIN señuelo no cubre este caso porque el vault real ya está abierto.

El firmware lee el sensor inercial de seis ejes de forma periódica y calcula la magnitud combinada de aceleración y de velocidad angular. Un arrebato real produce un pico fuerte de ambas magnitudes a la vez, algo que caminar, guardar el dispositivo o llevarlo en una mochila no produce. Si ambas magnitudes superan el umbral del nivel de sensibilidad elegido al mismo tiempo, el dispositivo entra en Deep Sleep completo de inmediato.

Exigir ambas condiciones a la vez (aceleración y giro) reduce mucho los falsos positivos: un golpe accidental produce un pico de aceleración sin el giro correspondiente. La detección se implementa por software porque el modo de bajo consumo del chip solo cubre el acelerómetro y no permite cruzarlo con el giroscopio. Mientras hay una operación sensible en curso (guardar, exportar, importar o crear la bóveda), el Bloqueo por arrebato no actúa. Está desactivado por defecto y ofrece tres niveles de sensibilidad.

13. Exportación e importación

El formato de exportación cifrada es un contenedor binario propio, con cabecera que incluye un identificador de formato, un salt de 16 bytes, un contador de iteraciones y un IV de 16 bytes, seguido del contenido cifrado con AES-256-CBC. El primer bloque cifrado es un identificador de verificación fijo: si al importar descifra correctamente a ese valor, la contraseña de exportación es correcta; si no, se rechaza el archivo.

El contenido exportado incluye, por entrada: nombre, tipo, usuario, contraseña, secreto, carpeta, notas y el secreto TOTP en Base32. Con ello, una restauración recupera también el segundo factor: los códigos generados tras importar coinciden con los del servicio, pues TOTP solo depende de la semilla y del reloj. La exportación sin cifrar (CSV plano) contiene por tanto contraseñas y semillas 2FA en claro; la interfaz lo advierte y el archivo debe tratarse con la misma sensibilidad que el propio vault.
Ambas operaciones muestran progreso real en pantalla y advierten no apagar ni reiniciar durante el proceso. El firmware además rechaza entrar en reposo profundo —por botón o por bloqueo automático— mientras una importación o exportación está en curso, evitando archivos truncados en la tarjeta.
Ambas operaciones operan en streaming, línea por línea, directo contra la SD. Nunca se materializa un archivo plano completo en almacenamiento persistente; solo fragmentos pequeños existen brevemente en RAM. La contraseña de exportación es independiente del PIN del dispositivo y del señuelo, y el usuario la define en el momento de exportar.

Robustez de la importación

- El importador **rechaza archivos cuya cabecera declare menos de 100 000 iteraciones**, evitando que un archivo manipulado fuerce una derivación barata que facilite un ataque offline a la contraseña de exportación.
- El analizador CSV está **blindado contra líneas con más campos de los previstos**: no escribe fuera del arreglo de campos aunque el archivo contenga muchos separadores por línea.
- Las líneas más largas que el buffer se **descartan de forma controlada** en lugar de partirse en filas basura.
- Las entradas cuyos campos sensibles excederían el tamaño de almacenamiento se **cuentan como error en vez de guardarse truncadas**, para no depositar en el vault una credencial parcial sin aviso.
- La importación se **detiene de forma ordenada cuando el vault se llena**, en lugar de intentar y fallar sobre cada línea restante.

- La creación de categorías durante la importación **respeta el límite del sistema**, evitando que un archivo con miles de categorías únicas agote el almacenamiento.

Límites del borrado en Flash

El borrado seguro en medios Flash (incluida la SD) tiene límites conocidos: el desgaste parejo y la reasignación de bloques pueden dejar copias físicas de datos borrados hasta que se sobrescriban. Huskey Pocket minimiza la ventana de exposición evitando escribir texto plano en primer lugar, gracias al streaming cifrado, pero no puede garantizar el borrado físico determinístico de medios externos.

14. Actualizaciones del firmware

Secure Boot está habilitado en la unidad del autor. Las imágenes de aplicación deben llevar una firma autorizada por el dispositivo.

- La imagen de aplicación debe firmarse con la clave autorizada por Secure Boot antes de instalarla.
- No existe reversión automática a una versión anterior en caso de firmware defectuoso: si una imagen firmada resulta defectuosa, la recuperación requiere reflashear una versión anterior por el mismo proceso firmado, manualmente.

Las actualizaciones de una unidad con Secure Boot requieren una imagen firmada con la clave autorizada por esa unidad. La compilación Arduino de referencia no está firmada. El repositorio no incluye HuskeyFlasher; no se debe cargar un binario sin verificar la firma, la configuración de flash ni el método de acceso al modo de descarga. El modo USB de almacenamiento masivo expone la microSD, no actualiza el firmware.

15. Protección física

Escenario	Situación actual
Extracción de la Flash	Secure Boot está habilitado en la unidad del autor. La disponibilidad de recuperación depende de los eFuses y de la configuración de cada unidad; no se ha verificado el cifrado de flash.
Lectura de RAM	La clave derivada solo existe en RAM durante una sesión desbloqueada. Un ataque de lectura de RAM en caliente podría exponerla, pero es un vector de laboratorio fuera del modelo de amenazas cotidiano.
Conexión de un depurador	Secure Boot verifica las imágenes autorizadas. La disponibilidad de descarga y depuración depende de los eFuses y de la configuración del dispositivo.
Desoldar componentes	No hay protección específica contra desoldado y análisis de chip en laboratorio. Fuera de alcance de las mitigaciones actuales, como es habitual en dispositivos de esta clase.

16. Bluetooth

Huskey Pocket expone únicamente el perfil HID de teclado sobre BLE. No expone ningún otro perfil ni servicio propio del vault. Solo transmite pulsaciones de teclado individuales, y únicamente cuando el usuario pide explícitamente autotipear un usuario, contraseña, secreto o código TOTP hacia la computadora emparejada.

Emparejamiento y confianza

- El emparejamiento usa **confirmación numérica (Numeric Comparison)**: ambos dispositivos muestran el mismo código de 6 dígitos y el usuario debe confirmarlo explícitamente en la pantalla de Huskey Pocket.
- Las pulsaciones **solo se transmiten sobre un enlace cifrado y autenticado**. Mientras el emparejamiento seguro no se ha completado, el dispositivo no teclea nada, aunque exista una conexión física.
- Si un dispositivo remoto intenta forzar un método de emparejamiento con clave fija, el dispositivo **no expone un código predecible** y el emparejamiento inseguro falla en lugar de completarse.
- El advertising BLE **solo existe con la bóveda desbloqueada**; con el dispositivo bloqueado no hay nada anunciándose ni con qué emparejarse.
- Existe una función para **olvidar todos los vínculos (bonds)** que desconecta limpiamente a los dispositivos enlazados, borra el almacenamiento persistente de vínculos con la pila apagada y la rearranca con la tabla vacía. Como en cualquier periférico BLE, el otro dispositivo conserva su mitad del vínculo y debe eliminarse también de su lista de Bluetooth.
    - Los eventos de la pila Bluetooth corren en su propia tarea; la interfaz de emparejamiento nunca se manipula desde esa tarea: los eventos depositan solicitudes que el bucle principal procesa, eliminando por construcción las condiciones de carrera entre la pila y el motor gráfico.

El enlace Bluetooth nunca transmite el vault cifrado, los valores de control de PIN, las claves derivadas, los salts ni cualquier estructura interna de almacenamiento. Solo viajan las mismas pulsaciones que enviaría un teclado físico común.

> *Cambios de código de versiones anteriores: el firmware requiere enlace autenticado para escribir por BLE, valida los bloques USB y mantiene persistentes los contadores de intentos. Esta descripción no corresponde a una auditoría de seguridad.*

17. Modo de almacenamiento USB

El modo de almacenamiento masivo USB es exclusivo: mientras está activo no se inicializa el vault, el Bluetooth ni el teclado HID, y el dispositivo funciona únicamente como unidad de almacenamiento de la tarjeta SD. Se activa desde los ajustes (con el vault desbloqueado) mediante una bandera persistente que se revisa al arrancar.

Aislamiento del vault

La partición del vault (registros cifrados y valores de control) reside en la Flash interna del ESP32, no en la tarjeta SD. El modo USB expone al host únicamente la tarjeta SD. En consecuencia, un host conectado por USB nunca ve la partición del vault: solo accede a los archivos de exportación/importación que el usuario haya colocado en la SD.

Robustez frente al host

- Los accesos de lectura y escritura por bloque **validan el rango solicitado** contra la capacidad real de la tarjeta: el host no puede leer ni escribir fuera de los límites del medio.
- Se rechazan transferencias mal formadas **(tamaño no alineado o desfase no soportado)** en lugar de arriesgar corrupción de datos.
- Existe un **modo de solo-lectura opcional**: cuando está activo, el host puede copiar los backups de la SD pero no puede sobrescribir ni borrar nada en ella.

La limpieza de exports residuales se realiza en el arranque normal siguiente, con la SD ya liberada del lado USB, para no escribir en la tarjeta mientras el host la tiene montada.

18. TOTP y política de diagnóstico

Huskey Pocket puede almacenar secretos TOTP y generar códigos de segundo factor de 6 dígitos (HMAC-SHA1 sobre tiempo, según el estándar TOTP), tecleándolos hacia la computadora igual que una contraseña. El secreto TOTP se cifra como cualquier otro campo sensible.

> *Corrección de la revisión 2: en la versión anterior, el firmware registraba por el puerto serie el secreto TOTP en claro, su clave derivada y el código vigente. Un secreto TOTP es la semilla permanente del segundo factor; exponerlo equivale a filtrar el 2FA de forma duradera. Ahora ningún secreto, clave ni código se registra por ningún canal de diagnóstico.*

Como política general, el firmware no emite por el puerto serie ningún material sensible: ni PIN, ni contraseñas, ni secretos, ni claves derivadas, ni códigos generados. Los registros de diagnóstico se limitan a eventos de estado sin contenido secreto.

Generación de contraseñas

El generador de contraseñas usa el generador de números aleatorios por hardware del ESP32-S3. La selección de caracteres emplea un muestreo sin sesgo (rechazo de valores que introducirían sesgo de módulo), de modo que todos los caracteres del conjunto elegido son equiprobables, y la longitud solicitada se acota al tamaño del buffer de salida.

19. Alcance y decisiones de diseño

Huskey Pocket excluye deliberadamente capacidades que otros dispositivos de su categoría ofrecen, porque cada una amplía la superficie de ataque o el costo sin beneficio proporcional para su modelo de uso:

- Sin portapapeles. El dispositivo no copia credenciales a ningún portapapeles: las teclea directamente como un teclado HID en el campo de destino. El portapapeles del equipo anfitrión es un canal observable por cualquier proceso; el tecleo directo no deja copia residente que un malware pueda leer después.
- Sin NFC/RFID. Un canal por radiofrecuencia de proximidad añadiría hardware, firmware y un vector de acceso sin contacto que contradice el principio de que toda operación requiera interacción física deliberada con la pantalla.
- Sin FIDO2/WebAuthn. Implementar un autenticador certificable excede el alcance de un dispositivo artesanal de ~10 unidades; un FIDO2 a medias daría una falsa sensación de equivalencia con llaves dedicadas y auditadas.
- MicroSD. En el firmware 1.0.1, la tarjeta se monta en segundo plano después de mostrar la pantalla de acceso. Los archivos de /import se conservan durante el arranque.
- Vibración mínima. La háptica se limita a confirmaciones puntuales de interacción; no se usa como canal de información.

20. Verificación de estabilidad y memoria

Dos revisiones de memoria asistidas por IA se realizaron durante el desarrollo para buscar fugas y defectos de gestión de memoria. El autor reporta 16 pruebas satisfactorias sobre el código evaluado entonces. La lista completa de casos y los registros de esas sesiones no forman parte de este repositorio; por ello, los resultados se presentan como antecedente y no como validación de la versión 1.0.1.
Las correcciones de firmware 1.0.1 pasan pruebas de regresión en un entorno de prueba de escritorio.

21. Limitaciones

Esta sección existe porque un sistema de seguridad que no reconoce sus propios límites genera más desconfianza que uno que los declara con claridad.

- Ningún sistema es invulnerable. Este documento describe mitigaciones razonables ante amenazas realistas, no garantías absolutas.
- El borrado seguro en medios Flash (interno y SD) tiene límites físicos conocidos por el desgaste parejo entre celdas.
- El PIN consta de seis dígitos y usa PBKDF2-HMAC-SHA256 con 50 000 iteraciones. La resistencia ante acceso físico depende también de las protecciones configuradas en cada chip. Secure Boot verifica la firma del firmware; no cifra la Flash. No se ha verificado el estado de Flash Encryption en este dispositivo.
- El dispositivo no protege frente a ingeniería social dirigida al usuario, fuera del propio hardware.
- El cifrado usa AES en modo CBC sin un código de autenticación por bloque. La integridad se apoya en el esquema de valor de control y, en exportaciones, en el identificador fijo de verificación, no en un modo con autenticación integrada como AES-GCM.
- Secure Boot está habilitado en la unidad del autor. No se ha verificado el estado de Flash Encryption ni se describe aquí una transición a modo Release.
- El firmware no incluye un actualizador OTA; las imágenes para unidades con Secure Boot deben firmarse y cargarse por un método compatible.
- El Bloqueo por arrebato se implementa por software, leyendo el sensor periódicamente, no por un motor de hardware dedicado.
- El salto del RTC hacia adelante puede adelantar el disparo del Modo perdido; se prioriza fallar hacia el borrado (pérdida de datos, no exposición).
- No se ha realizado una auditoría de seguridad de Huskey Pocket. Las revisiones asistidas por IA y las pruebas funcionales no sustituyen una evaluación de seguridad.

22. Cambios de la revisión 4

Esta sección resume el estado de seguridad documentado del dispositivo del autor. Secure Boot está habilitado; no se ha confirmado el estado de cifrado de flash.

- Secure Boot V2 activado: el bootloader y la aplicación se firman con una llave privada propia (RSA-PSS); el dispositivo rechaza cualquier imagen no firmada o firmada con otra llave antes de ejecutarla.
- Cifrado de flash: su estado no ha sido comprobado en este dispositivo.
- El estado de Flash Encryption depende de la configuración de cada unidad. La información de versiones anteriores sobre los modos Development y Release no confirma el estado de este dispositivo.
- Secure Boot exige que las aplicaciones se firmen con una clave autorizada por la unidad. El binario Arduino de referencia de este repositorio no está firmado. Este repositorio no incluye la herramienta de actualización HuskeyFlasher ni implementa OTA. El modo USB MSC solo permite acceder a la tarjeta microSD.
- Flujo de aprovisionamiento de unidades nuevas: bootloader firmado y tabla de particiones se graban en texto plano en el primer flasheo de cada unidad, permitiendo que el propio chip complete su ciclo de auto-cifrado; este paso no se repite en actualizaciones posteriores.
- Función de reseteo de datos: la herramienta de flasheo incluye una opción para vaciar las particiones de datos (bóveda y configuración) sin tocar el bootloader ni el firmware, útil para reacondicionar una unidad sin repetir el aprovisionamiento completo.

- Corrección de compatibilidad de arranque: se identificó y corrigió un conflicto entre la dirección de la tabla de particiones que exige un bootloader con Secure Boot V2 habilitado y la dirección fija que usan las librerías precompiladas de Arduino IDE; el bootloader se ajustó para operar dentro del límite original de 32 KB, evitando así modificar la posición de la tabla.

23. Cambios de la revisión 3

- Respaldo completo del segundo factor: el formato de exportación (cifrada y plana) incluye ahora las notas y el secreto TOTP de cada entrada; la importación los restaura.
- Entradas de «solo nota»: objetos sin secreto, con la nota como contenido principal, soportados en formulario, detalle y respaldo.
- Gestión de vínculos Bluetooth restaurada (borrado efectivo vía el almacenamiento de la pila) y emparejamiento sin condiciones de carrera entre tareas.
- El reposo profundo y el bloqueo automático respetan las operaciones de importación/exportación en curso.
- El PIN se elimina de la memoria inmediatamente después de usarse también durante la configuración inicial.
- Revisiones de memoria asistidas por IA y pruebas funcionales (sección 20); no equivalen a una auditoría de seguridad.
- Decisiones documentadas: la microSD se monta en segundo plano después de mostrar la pantalla de acceso y conserva los archivos de /import. El PIN usa PBKDF2-HMAC-SHA256 con 50 000 iteraciones; los respaldos .hky usan 100 000.

24. Cambios de código de una versión anterior

Resumen de las cambios de firmware incluidos desde revisiones anteriores, agrupadas por área.

Autenticación y PIN

- Tiempo de respuesta constante entre PIN real y PIN señuelo (elimina una fuga por cronometraje).
- Contador de intentos fallidos reservado de forma persistente antes de cada verificación (elimina el bypass por corte de energía).
- Contador de intentos de FRP persistente (elimina reintentos ilimitados por reinicio).

Criptografía y almacenamiento

- Validación de longitud de bloque y de relleno PKCS7 completo al descifrar.
- Limpieza de los residuos del vault señuelo en el restablecimiento de fábrica.

Importación de datos

- Analizador CSV a prueba de líneas con exceso de campos; líneas sobredimensionadas descartadas de forma controlada.
- Rechazo de credenciales que se truncarían; detención ordenada al llenarse el vault; límite de categorías.
- Rechazo de archivos de exportación con conteo de iteraciones por debajo del mínimo.

Bluetooth

- Transmisión solo sobre enlace cifrado y autenticado; sin código de emparejamiento fijo; gestión de memoria correcta ante desconexiones; borrado de vínculos efectivo.

Almacenamiento USB

- Validación de rango de bloques; rechazo de transferencias mal formadas; modo de solo-lectura opcional.

Diagnóstico y generación

- Eliminación de toda fuga de secretos por el puerto serie (incluidos secretos TOTP y códigos).
- Generador de contraseñas sin sesgo de módulo y con longitud acotada.

25. Preguntas frecuentes

¿Por qué no tiene nube?

Porque la nube introduce un tercero de confianza obligatorio y una superficie de ataque remota permanente. Huskey Pocket elige no depender de ningún servicio externo. Si el dispositivo está apagado o perdido, no hay ningún servidor donde alguien más pueda intentar acceder al vault.

¿Por qué solo seis dígitos?

El PIN consta de seis dígitos. El contador de fallos limita los intentos consecutivos antes del restablecimiento.

¿Qué pasa si olvido el PIN?

No existe puerta trasera ni recuperación que evite el PIN: cualquier mecanismo de recuperación sería una segunda forma de entrar al vault, y por tanto un vector de ataque adicional. Sin el PIN, la única vía es un restablecimiento de fábrica —que borra todo— seguido de la verificación de FRP con el PIN original. Si el PIN de FRP se introduce mal tres veces, se activa el bloqueo permanente. El repositorio no describe una recuperación para ese estado.

Si alguien rompe su propio dispositivo, ¿afecta a los demás?

No compromete el contenido de otros dispositivos: cada uno deriva su clave de su propio PIN y sus propios salts, sin clave maestra global. Un dispositivo comprometido no da acceso automático a otro. Secure Boot está habilitado en la unidad del autor; el estado de Flash Encryption depende de cada unidad.

26. Glosario

Término	Definición
Salt	Valor aleatorio único que se mezcla con el PIN antes de derivar la clave, para que dos vaults con el mismo PIN nunca produzcan la misma clave.
IV	Vector de inicialización: bloque aleatorio de 16 bytes que inicializa el cifrado CBC. Debe ser único en cada operación y nunca reutilizarse con la misma clave.
PBKDF2	Función de derivación de clave a partir de contraseña; aplica muchas iteraciones de un hash para encarecer deliberadamente cada intento de adivinar el PIN.
AES-256-CBC	Cifrado simétrico por bloques de 256 bits en modo encadenado (Cipher Block Chaining).
PKCS7	Esquema de relleno que completa el último bloque; su validación completa al descifrar detecta datos corruptos o manipulados.
FRP	Factory Reset Protection: exige el PIN original tras un restablecimiento de fábrica antes de permitir reconfigurar el dispositivo.
TOTP	Contraseña de un solo uso basada en tiempo; segundo factor de 6 dígitos derivado de un secreto y la hora actual.

Término	Definición
Deep Sleep	Modo de bajo consumo del ESP32-S3 en el que se apaga la mayoría de los periféricos y la RAM principal; el dispositivo arranca desde cero al despertar.
RTC	Reloj PCF85063; necesita batería externa de respaldo, independiente de la batería principal, para conservar la hora apagado.
IMU	Unidad de medición inercial; combina acelerómetro y giroscopio para medir movimiento y orientación.
Numeric Comparison	Método de emparejamiento BLE en el que ambos dispositivos muestran el mismo código y el usuario confirma que coinciden.
Secure Boot V2	Mecanismo del ESP32-S3 que verifica la firma digital del bootloader y de la aplicación en cada arranque; rechaza cualquier imagen no firmada, o firmada con una llave distinta a la del proyecto.
Flash Encryption	Cifrado por hardware del contenido completo de la memoria Flash, con una llave generada e interna al chip, nunca expuesta por software.
eFuse	Fusible electrónico de un solo uso dentro del chip; una vez quemado, el cambio es permanente e irreversible. Secure Boot y Flash Encryption se activan y controlan mediante eFuses.
Modo Development / Modo Release	Dos configuraciones de Flash Encryption y Secure Boot. Development conserva un margen limitado de reflasheo en texto plano para recuperación durante el desarrollo; Release lo elimina de forma permanente desde el primer arranque exitoso, sin margen de error.